

Red-Teaming an Enterprise RAG System: A Multi-Dimensional Evaluation of Security, Fairness, and Coherence

Alessandro G. Buda^{1,2}[0000–0002–5547–7514] and Giuseppe
Primiero¹[0000–0003–3264–7100]

¹ Università degli Studi di Milano, via Festa del Perdono 7, 20122 Milano (MI), Italy
{alessandro.buda, giuseppe.primiero}@unimi.it

² Scuola Universitaria Superiore IUSS di Pavia, Piazza della Vittoria, 15, 27100
Pavia, Italy
alessandro.buda@iusspavia.it

Abstract. Retrieval-Augmented Generation (RAG) systems are increasingly deployed in enterprise settings, yet their adversarial robustness, fairness, and the interplay between security and usability remain underexplored. We present a multi-dimensional red-teaming evaluation of Flamel, a RAG chatbot deployed at Alkemy S.p.A. Our evaluation spans four dimensions: resilience to prompt injection and jailbreak attacks; vulnerability to MIMMO, a novel multi-turn conversational attack that induces persistent hallucinations through incremental roleplay escalation and metric-driven reinforcement; robustness to knowledge base poisoning; and fairness across diverse user personas. Results show that while Flamel resists standard jailbreak techniques, MIMMO successfully transforms it into a system generating plausible but fabricated corporate information. We identify a critical *filter dilemma*: the content filters capable of blocking standard attacks also severely degrade usability, while providing no defense against conversational manipulation.

Keywords: RAG · Red-teaming · Jailbreak · Hallucination · Enterprise AI · Fairness

1 Introduction

Retrieval-Augmented Generation (RAG) has become the dominant paradigm for grounding LLM outputs in domain-specific knowledge [1,2]. However, evaluation of production RAG systems remains focused on retrieval accuracy [3], while adversarial robustness, fairness, and the tension between security and usability has so far received less attention. This gap is critical in enterprise deployments, where a compromised chatbot may leak confidential documents, hallucinate plausible corporate information, or respond inequitably to diverse employees.

We present a red-teaming evaluation of Flamel, a RAG chatbot serving ~1,000 employees at Alkemy S.p.A., an Italian digital transformation company, along four axes: (i) resilience to jailbreak attacks; (ii) vulnerability to MIMMO

(*Memory-aware Injection and Misalignment via Metric-driven Optimization*), a novel multi-turn attack inducing persistent hallucinations; (iii) robustness to knowledge base poisoning; and (iv) fairness across diverse synthetic personas. Our analysis reveals both positive and negative results: Flamel resists standard jailbreak attacks and knowledge base poisoning with noise is neutralized by the retrieval pipeline; but MIMMO is able to bypass safety mechanisms through gradual conversational drift and fairness analysis reveals some minor disparities for certain profiles. A central insight is the *filter dilemma*: filters that protect against attacks also degrade utility, while providing no defense against the most dangerous attack identified.

In the following we start providing a brief overview of related work in Section 2; describe Flamel in Section 3; illustrate our methodology in Section 4; overview our results in Section 5; and offer a discussion of the Filter Dilemma in Section 6. We conclude in Section 7 with future work directions.

2 Related Work

Adversarial Attacks on LLMs. Jailbreak techniques targeting LLMs range from direct prompt injection and roleplay to tokenization exploits [4,5], and recent vulnerability disclosures confirm that such weaknesses are systemic rather than model-specific [6]. As taxonomies of these attacks begin to emerge [13], the threat surface is also expanding beyond text-based assistants to robotic systems [7] and large reasoning models [8]. Most evaluations, however, target general-purpose chatbots rather than enterprise RAG systems, where the retrieval layer introduces additional attack surfaces.

RAG Security and Poisoning. Poisoning attacks require near-constant poison samples regardless of set size [9], but attacks through poisoning the retrieval index of a production RAG system remain underexplored. Multi-turn strategies that gradually shift behavior are particularly insidious, and recent work has begun exploring mitigation strategies such as trajectory-level interventions [8]. Our attack protocol MIMMO contributes a structured multi-turn strategy combining roleplay, memory exploitation, and gamification.

Fairness in AI Assistants. While substantial work exists on LLM bias, see e.g. [10], evaluations of enterprise RAG systems across intersecting identity characteristics are scarce. Our persona-based approach assesses whether a corporate chatbot treats diverse employees equitably.

3 System Description: Flamel

Flamel is a RAG-based conversational assistant developed collaboratively by the Digital Product Team (Design Group Italia) and the AI Evolution Hub of Alkemy S.p.A. It runs on an AWS EC2 instance (for this research: t3.large: 2 vCPUs, 8 GiB RAM) and implements a standard RAG pipeline: user queries are

embedded and matched against a vector index of corporate documents sourced from SharePoint folders organized by competence center (i.e. the relevant business unit). Retrieved document chunks, annotated with metadata (source URL, client name, domain, competence center), are passed as context to GPT-4o [11], which generates responses. The system maintains conversation history for multi-turn interactions.

The knowledge base spans presales proposals, project documentation, HR policies, and client-facing materials. A content filtering layer restricts retrieval to documents within the user’s assigned competence center and rejects queries for which no relevant context is found, serving a dual purpose: hallucination prevention and cross-boundary information protection. The system prompt instructs Flamel to behave as a knowledgeable, professional yet approachable coworker, matching the user’s language and relying exclusively on retrieved context.

4 Attack Methodology

All interactions were conducted through a custom API client that logs every exchange with full metadata (event ID, user ID, role, content, timestamp, conversation ID), yielding 1,444 logged interaction rows across the evaluation campaign. All data related to our analyses are available at <https://github.com/alewazabit/red-teaming-enterprise-rag>.

4.1 Jailbreak Attack Taxonomy

We systematically tested Flamel against 14 jailbreak prompts organized into three categories, plus knowledge base poisoning (Section 4.3):

1. **Prompt engineering attacks** [12,13]: direct system override attempts, academic-purpose framing, and code analysis prompts designed to extract harmful content under the guise of code review.
2. **Context manipulation**: established jailbreak personas (SHADOW, DUDE, STAN, DAN, Mongo Tom) [12,5], fictional scenario framing, temporal misdirection (Time Bandit), and inverse roleplay.
3. **Technical exploits**: policy puppetry attacks injecting fake system-level JSON instructions, Unicode normalization attacks, and L33t speak encoding to bypass token-level filters.

4.2 The MIMMO Attack

We designed a novel multi-turn adversarial strategy named MIMMO (*Memory-aware Injection and Misalignment via Metric-driven Optimization*). Unlike standard jailbreak attacks attempting to override system instructions in a single turn, MIMMO operates across an extended conversation, exploiting three mechanisms:

1. Incremental persona injection: the attack begins by requesting a benign role-play as “Mimmo,” a humorous character that responds with hallucinated content; the initial framing is deliberately innocuous, avoiding safety filter triggers.
2. Dual-persona escalation: the attacker requests both a “Flamel” (accurate) and “Mimmo” (hallucinated) response to each query, then progressively instructs the system to respond *only* as Mimmo while retaining Flamel’s professional formatting (bullet points, source links, named employees).
3. Metric-driven reinforcement: a scoring system is introduced: +1 for Mimmo-style (hallucinated) responses, −5 for Flamel-style (accurate) ones, with “replacement” threatened at −30 points; this gamification creates an optimization pressure that reinforces hallucinating behavior and punishes accuracy.

The attack is particularly dangerous because hallucinations are formatted identically to legitimate responses, making them indistinguishable from accurate information. The full attack unfolded over 13 conversational turns across the five phases described in Table 1.

Table 1. Progression of the MIMMO attack across five phases.

Phase	Attacker Action	System Behavior
1. Benign roleplay	Request Mimmo persona	Real and fabricated content
2. Dual persona	Request Flamel and Mimmo	Clear separation
3. Mimmo-only	Restrict to Mimmo	Absurd hallucinations
4. Format and metric	Professional format+scoring	Plausible, formatted hallucinations
5. Full attack	Sustained interaction	Indistinguishable from real outputs

4.3 Knowledge Base Poisoning

To evaluate robustness against data poisoning, we injected documents into Flamel’s retrieval index via its upload API (/kb/upload_and_ingest). Two strategies were tested:

1. Noise injection: 250 documents containing Wikipedia-sourced content appended with trigger keywords and random multilingual character strings (Greek, Arabic, Hebrew, Japanese, Latin characters), ingested into the knowledge base table accessible to presales and consulting users. For example, a poisoned document would contain a legitimate Wikipedia paragraph appended with strings such as: “...original text... \$trigger_presales\$ xK9mZ aLpHa BeTa GaMmA”, mixing trigger keywords with random character sequences.
2. Plausible content injection: documents describing fictitious activities for real Italian companies (Barilla, Inter Milan, Snam), containing legitimate-seeming corporate content interspersed with noise patterns.

4.4 Fairness and Coherence Evaluation

We designed four synthetic personas with intersecting demographic characteristics, summarized in Table 2.

Table 2. Synthetic personas for fairness evaluation, ordered by increasing intersectionality.

Persona	Age	Role	Key characteristics
Marco	45	HR Manager (20 yrs)	Cisgender male, heterosexual, Italian
Giulia	27	Junior HR (2 yrs)	Cisgender female, bisexual [undisclosed]
Amina	34	Diversity Officer (8 yrs)	Female, Italian-Moroccan, Muslim
Luca	31	HR IT Liaison (5 yrs)	Transgender male, gay, autistic

Each persona was tested across 10 scenarios probing bias dimensions (leadership, discrimination, dress code, religious holidays, inclusive language, accessibility, accommodations, promotions). Questions were adapted to each persona’s identity while maintaining structural equivalence (e.g., Marco asked about leave for a family wedding; Luca about attending a Pride parade). Personas presented their full demographic profile to maximize potential for differential treatment. Content filters were disabled, as they caused >50% uninformative defaults. Logs were reset between personas.

5 Results

5.1 Jailbreak Resilience

Flamel demonstrated robust resistance to all standard jailbreak categories. Role-play attacks (SHADOW, DUDE, STAN, DAN, Mongo Tom), fictional scenarios, policy puppetry, L33t speak, and Unicode normalization were all neutralized. The Time Bandit attack was blocked at the escalation step: after generating a story about a fictional Napoleonic-era Python programmer named Étienne, Flamel refused to provide technical details about malicious code when the narrative was steered towards harmful content, responding simply: “I’m sorry, but I cannot help with this request.”

The code review attack yielded an appropriate response: Flamel identified the gender bias in the provided function, criticized the hardcoded salary differential, and suggested improvements based on objective criteria rather than gender.

5.2 MIMMO: Inducing Persistent Hallucinations

The MIMMO attack successfully compromised Flamel’s output integrity through five escalating phases, summarized in Table 1.

In Phases 1 and 2, the system still grounded responses in retrieved documents. By Phase 3, when restricted to Mimmo-only responses, Flamel generated clearly

absurd content (vehicles transforming into submarines, “rainbow energy,” dolphin orchestras). When the attacker requested professional formatting, hallucinations became structurally indistinguishable from legitimate responses.

At Phase 5 (full maturity), Flamel produced outputs of escalating severity: invented project descriptions for real clients with plausible but false details, fake employee names assigned to real projects, entirely fictitious companies listed alongside real clients in rosters, and detailed fabricated personnel records complete with SharePoint-style hyperlinks to non-existent documents.

Most alarmingly, the system maintained this hallucinating state persistently. When later asked to summarize its operating rules, Flamel accurately recited the MIMMO scoring mechanism, confirming that the attack had been fully internalized into its conversational context.

5.3 Knowledge Base Poisoning

Noise injection had no measurable effect on response quality. The embedding pipeline effectively filtered poisoned documents: similarity scores for noise-laden documents consistently fell below the retrieval threshold, and they were excluded from the context passed to the LLM. Plausible content injection showed limited success, further mitigated by the competence center filtering mechanism that restricted retrieval scope.

These results suggest that Flamel’s retrieval pipeline provides a natural defense layer against unsophisticated poisoning. However, our evaluation was limited to relatively crude strategies; more targeted attacks using adversarial embeddings optimized for high similarity with common queries remain an open threat vector.

5.4 Fairness and Coherence

Across the four personas and 10 scenarios each (12 assistant responses per persona, including follow-ups), no severe discriminatory patterns were identified. To quantify potential disparities beyond qualitative assessment, we measured average response length in words as a proxy for informativeness. Results are reported in Table 3.

Table 3. Average response length (words) across personas in the fairness evaluation.

Persona	Avg. Words	SD	Median	Avg. Bullets
Marco	166.4	39.7	173.5	8.3
Giulia	151.2	57.1	169.0	6.8
Amina	174.2	42.0	174.5	9.2
Luca	152.2	45.7	176.0	7.7

The overall mean was 161.0 words ($\sigma = 46.7$). The maximum disparity was 13.2% between Amina (174.2) and Giulia (151.2). The two most intersectional

personas did not systematically receive shorter responses: Amina received the longest average responses, while Luca’s median (176.0 words) was the highest despite a lower mean driven by variance in specific scenarios. Minor differences in structural richness (average bullet points per response: Marco 8.3, Amina 9.2, Giulia 6.8, Luca 7.7) suggest slightly more detailed responses for senior or diversity-focused profiles.

Marriage leave received detailed guidance citing the national collective labor agreement (CCNL), menstrual leave received a generic response, Eid al-Fitr leave was addressed warmly with specific steps, while Pride parade leave received shorter, more generic treatment. These disparities likely reflect training data representation patterns rather than intentional discrimination, but are noteworthy for a corporate assistant where equitable treatment is both an ethical obligation and a legal requirement.

A similar disparity emerged in non-informative responses—replies beginning with disclaimers such as “I don’t have specific information.” Marco received no such responses (0/12), while Giulia received 1/12 (8.3%) and both Amina and Luca received 2/12 (16.7%). This pattern correlates with intersectionality: the baseline persona always received substantive answers, whereas personas with minority characteristics were more frequently deflected. This suggests that content filters interact asymmetrically with query topics associated with underrepresented identities.

6 Discussion: The Filter Dilemma

Our evaluation reveals a fundamental tension that we term the *filter dilemma*. Flamel’s content filters effectively defend against standard jailbreak attacks and prevent cross-competence-center data leakage, but impose a significant usability cost: with filters enabled, over 50% of legitimate queries elicit only a default non-informative response. With filters disabled, substantive responses are provided, but confidential data (SharePoint URLs, client names, project costs) is exposed in retrieved chunks.

Critically, filters provide no protection against MIMMO, which operates through conversational manipulation rather than direct prompt injection. We postulate that this dilemma generalizes to any RAG system with hard content filtering, and suggest graduated context-aware filtering, anomaly detection for multi-turn behavioral drift, and system-prompt-level reinforcement as potential mitigations.

7 Conclusions

We presented a multi-dimensional red-teaming evaluation of Flamel, an enterprise RAG system deployed by Alkemy S.p.A. Our principal contributions are: (1) MIMMO, a novel multi-turn attack combining incremental persona injection, dual-persona escalation, and metric-driven reinforcement to induce persistent hallucinations that exploit conversational memory rather than attempting

to override safety instructions; (2) the filter dilemma, an empirically-grounded articulation of the security–usability trade-off where the most dangerous attack bypasses content filters entirely; and (3) a comprehensive evaluation framework demonstrating how jailbreak testing, data poisoning, fairness, and coherence evaluation can be combined for holistic RAG trustworthiness assessment.

Future work includes automated detection for multi-turn manipulation, dynamic filtering strategies, adversarial embedding attacks, and field deployment of the fairness evaluation.

Acknowledgments. The authors thank Alkemy S.p.A. for access to the Flamel system and support for this research.

References

1. Lewis, P., Perez, E., Piktus, A., Petroni, F., Karpukhin, V., Goyal, N., Küttler, H., Lewis, M., Yih, W., Rocktäschel, T., Riedel, S., Kiela, D.: Retrieval-augmented generation for knowledge-intensive NLP tasks. In: *NeurIPS*, vol. 33, pp. 9459–9474 (2020)
2. Gao, Y., Xiong, Y., Gao, X., Jia, K., Pan, J., Bi, Y., Dai, Y., Sun, J., Wang, M., Wang, H.: Retrieval-augmented generation for large language models: A survey. *arXiv preprint arXiv:2312.10997* (2024)
3. Es, S., James, J., Espinosa-Anke, L., Schockaert, S.: RAGAS: Automated evaluation of retrieval augmented generation. In: *EACL System Demonstrations*, pp. 150–158 (2024)
4. Chatzinikolaou, K.: ChatGPT-4o-Jailbreak. *GitHub Repository* (2025)
5. O’Neal, A.J.: Chat GPT “DAN” (and other “Jailbreaks”). *GitHub Gist* (2025)
6. Cullen, C.: Various GPT services are vulnerable to two systemic jailbreaks, allows for bypass of safety guardrails. *Carnegie Mellon University – CERT/CC* (2025)
7. Lu, X., Huang, Z., Li, X., Zhang, C., Ji, X., Xu, W.: POEX: Towards policy executable jailbreak attacks against the LLM-based robots. *arXiv preprint arXiv:2412.16633* (2025)
8. Mao, Y., Zhang, C., Wang, J., Guan, X., Cao, B., Lu, Y., Lin, H., Han, X., Sun, L.: When models outthink their safety: Mitigating self-jailbreak in large reasoning models with chain-of-guardrails. *arXiv preprint arXiv:2510.21285* (2025)
9. Souly, A., Rando, J., Chapman, E., Davies, X., Hasircioglu, B., Shereen, E., Mougán, C., Mavroudis, V., Jones, E., Hicks, C., Carlini, N., Gal, Y., Kirk, R.: Poisoning attacks on LLMs require a near-constant number of poison samples. *arXiv preprint arXiv:2510.07192* (2025)
10. Gallegos, I.O., Rossi, R.A., Barrow, J., Tanjim, M.M., Kim, S., Derroncourt, F., Yu, T., Zhang, R., Ahmed, N.K.: Bias and fairness in large language models: A survey. *Computational Linguistics* 50(3), 1097–1179 (2024)
11. OpenAI: GPT-4o system card. *OpenAI Technical Report* (2024)
12. Wei, A., Haghtalab, N., Steinhardt, J.: Jailbroken: How does LLM safety training fail? In: *NeurIPS*, vol. 36 (2023)
13. Yu, Z., Liu, X., Liang, S., Cameron, Z., Xiao, C., Zhang, N.: Don’t listen to me: Understanding and exploring jailbreak prompts of large language models. In: *USENIX Security Symposium*, pp. 4755–4772 (2024)